

IS Audit Process

FLORENCE LOVE NKOSI, **CISA|CEH**

IT Audit Process

To successfully carry out an IT audit, Auditors follow this process:



Planning

- Before you begin work on any audit, you must determine what you plan to review.
- The goal of the planning process is to determine the objectives and scope of the audit.
- You need to determine just what it is you're trying to accomplish with the review.
- You should develop a series of steps to be executed in order to accomplish the audit's objectives – **Audit plan.**

Planning

Before any audit, IS auditors must determine what they plan to review and then develop audit objectives and audit plan for the audit assignment.

The planning comprise of the following steps:

- Preliminary assessment and information gathering
- Risk assessment to define audit objective and scope
- Develop Audit plan and program
- Entry Meeting / Kickoff meeting

Planning - **Preliminary Survey**

- **Preliminary Survey** The audit team should spend some time before each audit performing a preliminary survey of the area to be audited to understand what the audit will entail.
- This likely will include interviews with the audit customers to understand the function of the system or processes being reviewed, as well as review of any pertinent documentation.
- The goal is to obtain a basic background and understanding of the area to be reviewed but also the organization process(especially if its your first audit).

Planning- **Preliminary Survey**

- Understanding the organizations process and the audit area is important as it becomes input for risk assessment.
- This process also allows you to understand Customer Requests
  - Auditing is a collaborative and cooperative process the Clients/customers being audited must be included.
  - Ask clients if there are any areas they would like to be reviewed.
  - The auditors must ultimately apply their best judgment.
  - However, obtaining the customers' input and incorporating it into the audit plan where possible will make the customers feel ownership in the audit project and optimize open and honest communication.

Planning - Understanding organization

- The IT auditor has to gather knowledge and inputs of the client in order to understand their business objectives and the IT environment.
- IS auditors should aim to understand: Organizational Structure, Criticality of IT systems, Nature of hardware and software used among others.

The auditor can gather the required information by:

- Reading background material including organization publications, annual reports and independent audit/analytical reports.
- Reviewing long-term strategic plans.
- Interviewing key personnel to understand business issues.
- Visiting key organization facilities.

RISK / IT RISK

- **Threat :** an action or event that has potential to compromise and violate security
- **Vulnerability:** a **weakness of an asset** (resource) or a group of assets that can be exploited by one or more threats.
-
- A **Risk** is defined as the possibility of an event occurring that will have an impact on the achievement of objectives and is measured in terms of impact and likelihood
  - Risk = **Likelihood × Impact**
- Risk is defined as the **potential** for loss or damage when a threat exploits a vulnerability.

RISK / IT RISK



From bmcblogs :https://www.bmc.com/blogs

IT RISK Categories

Physical threats - resulting from physical access or damage to IT resources such as the servers. These could include **theft, damage from fire or flood, or unauthorized access to confidential data by an employee or outsider.**

Electronic threats - aiming to compromise your business information - eg a hacker could get access to your website, your IT system could become infected by a computer virus, or you could fall victim to a fraudulent email or website..

Technical failures - such as software bugs, a computer crash or the complete failure of a computer component. A technical failure can be catastrophic if, for example, you cannot retrieve data on a failed hard drive and no backup copy is available.

Infrastructure failures -

such as the loss of your internet connection can interrupt your business - eg you could miss an important purchase order.

Human error - is a major threat - eg someone might accidentally delete important data, or fail to follow security procedures properly.

Risk analysis

- Risk analysis is part of the audit planning and helps identify risks and vulnerabilities so the IS auditor can determine the controls needed to mitigate those risks.
- An independent risk analysis by the auditor not only helps identify areas that have to be examined but also in determining audit objectives and supporting risk based audit decisions.

Risk analysis

From the IS audit's perspective, risk analysis serves more than one purpose:

- It assists the IS auditor in identifying risks and threats to an IT environment and IS system.
- It helps the IS auditor in his/her evaluation of controls in audit planning
- It assists the IS auditor in determining audit objectives
- It supports risk-based audit decision making

- **Note:** Risk-based auditing is a style of auditing which focuses upon the analysis and management of risk.

Risk analysis

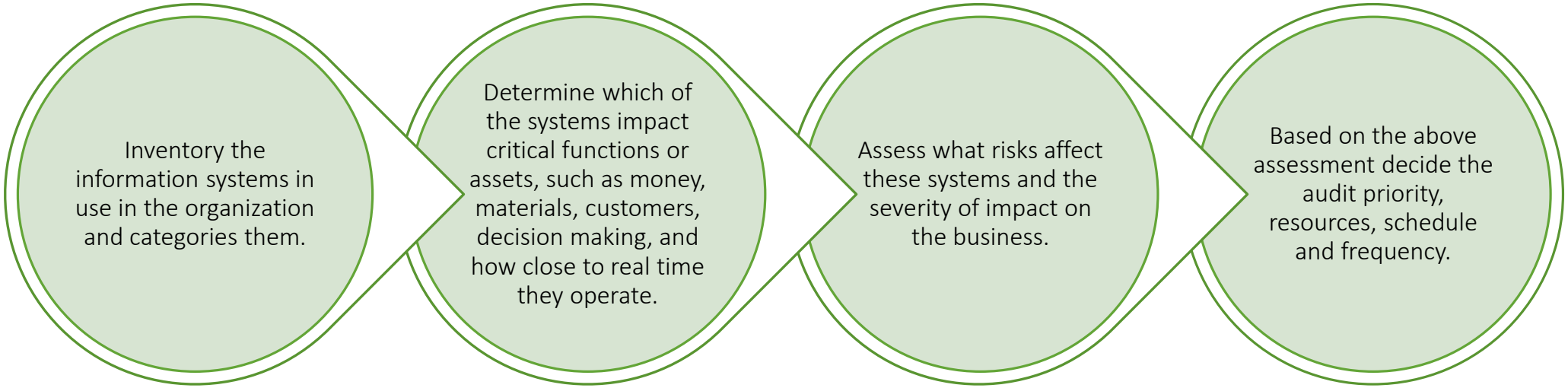
- To carry out a Risk Analysis, you must first identify the possible threats that you face, then estimate their likely impacts if they were to happen, and finally estimate the likelihood that these threats will materialize.
- Risk analysis works hand in hand with Risk assessment, sometimes separated and sometimes put together. Risk analysis leads to risk assessment.

.

Planning- IT Risk assessment

- A **risk assessment** is a systematic process to evaluate, identify, and prioritize potential audits based on the level of **risk** to the organization.
- **IT risk assessment** is a process of analyzing potential threats and vulnerabilities to your IT systems to establish what loss you might expect to incur if certain events happen. Its objective is to help you achieve optimal security at a reasonable cost.
- Risk assessment should identify, quantify and prioritize risks against criteria for risk acceptance and objectives relevant to the organization. The result should guide and determine the appropriate management action, priorities for managing information security risks and priorities for implementing controls to protect against the risk.
- Risk assessment should be performed periodically to address changes in the environment and in security requirement and the risk situations (in the assets, threats, vulnerabilities, impact)

Risk Assessment- Steps



Systems at Mzuni

Student Management System

Hostel Allocation system

Library Management system

Planning- Risk Assessment Process

1. Identify and Prioritize Assets
2. Identify Threats
3. Identify Vulnerabilities
4. Analyze Controls
5. Determine likelihood of an incident
6. Assess the impact a threat could have
7. Prioritise information security risks
8. Recommend the controls and
9. Document the results

Planning - IT RISK ASSESMENT METHODOLOGY

- There are two prevailing methodologies for assessing the different types of IT risk:
  - Quantitative Risk assessment
  - Qualitative risk assessment

Quantitative risk assessment

- Quantitative assessment measures risk using monetary amounts. It uses mathematical formulas to give you the value of expected losses associated with a particular risk, based on:
  - the asset value
  - the frequency of risk occurrence
  - the probability of associated loss
- In **an example of server failure**, a quantitative assessment would involve looking at:
  - the cost of a server or the revenue it generates
  - how often does the server crash
  - the estimated loss incurred each time it crashed

Quantitative risk assessment (cont.)

- These monetary results could help you avoid spending too much time and money on reducing negligible risks. For example, if a threat is unlikely to happen or costs little or nothing to remedy, it probably presents **low risk** to your business.
- However, if a threat to your key IT systems is likely to happen, and could be expensive to fix or likely to affect your business adversely, you should consider it **high risk**.
- You may want to use this risk information to carry out a **cost/benefit analysis** to determine what level of investment would make risk treatment worthwhile.
- Keep in mind that quantitative measures of risk are only meaningful when you have **good data**. You may not always have the necessary historical data to work out probability and cost estimates on IT-related risks, since they can change very quickly.

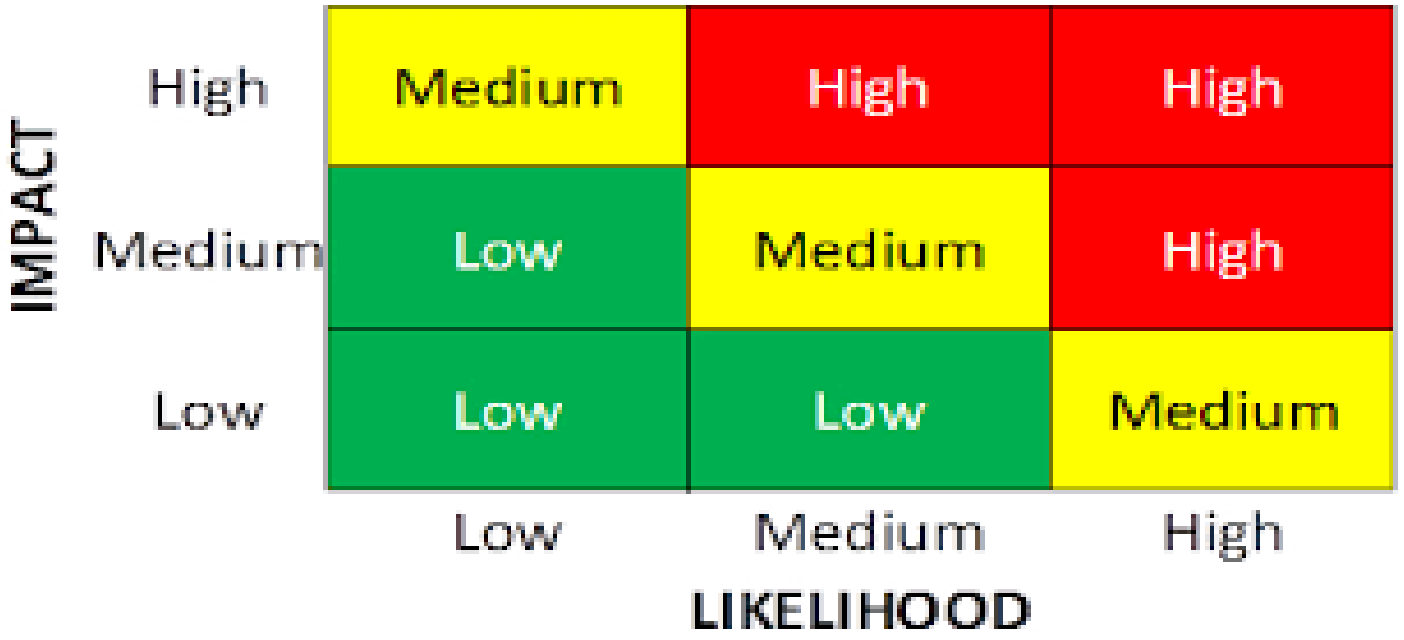
Qualitative risk assessment

- **Qualitative risk assessment** is opinion-based. It relies on judgment to categorise risks based on probability and impact and uses a **rating scale** to describe the risks as:
  - **low** - unlikely to occur or impact your business
  - **medium** - possible to occur and impact
  - **high** - likely to occur and impact your business significantly
- For example, you might classify as 'high probability' something that you expect to happen several times a year.
- You do the same for cost/impact in whatever terms seem useful, for example:
  - low - would lose up to half an hour of production
  - medium - would cause complete shutdown for at least three days
  - high - would cause irrevocable loss to the business

Qualitative risk assessment (cont.)

- A **risk matrix** is a matrix that is used during risk assessment to define the level of risk by considering the category of probability or likelihood against the category of consequence severity.
- The risk assessment matrix is used to basically analyze two variables: impact and the probability of a specific event occurring.
- These variables are meant to evaluate the impact of risks in comparison to consequences and their chance of happening.
- The focus of the matrix is to position specific issues in the risk assessment matrix according to their probability rating.

Risk matrix

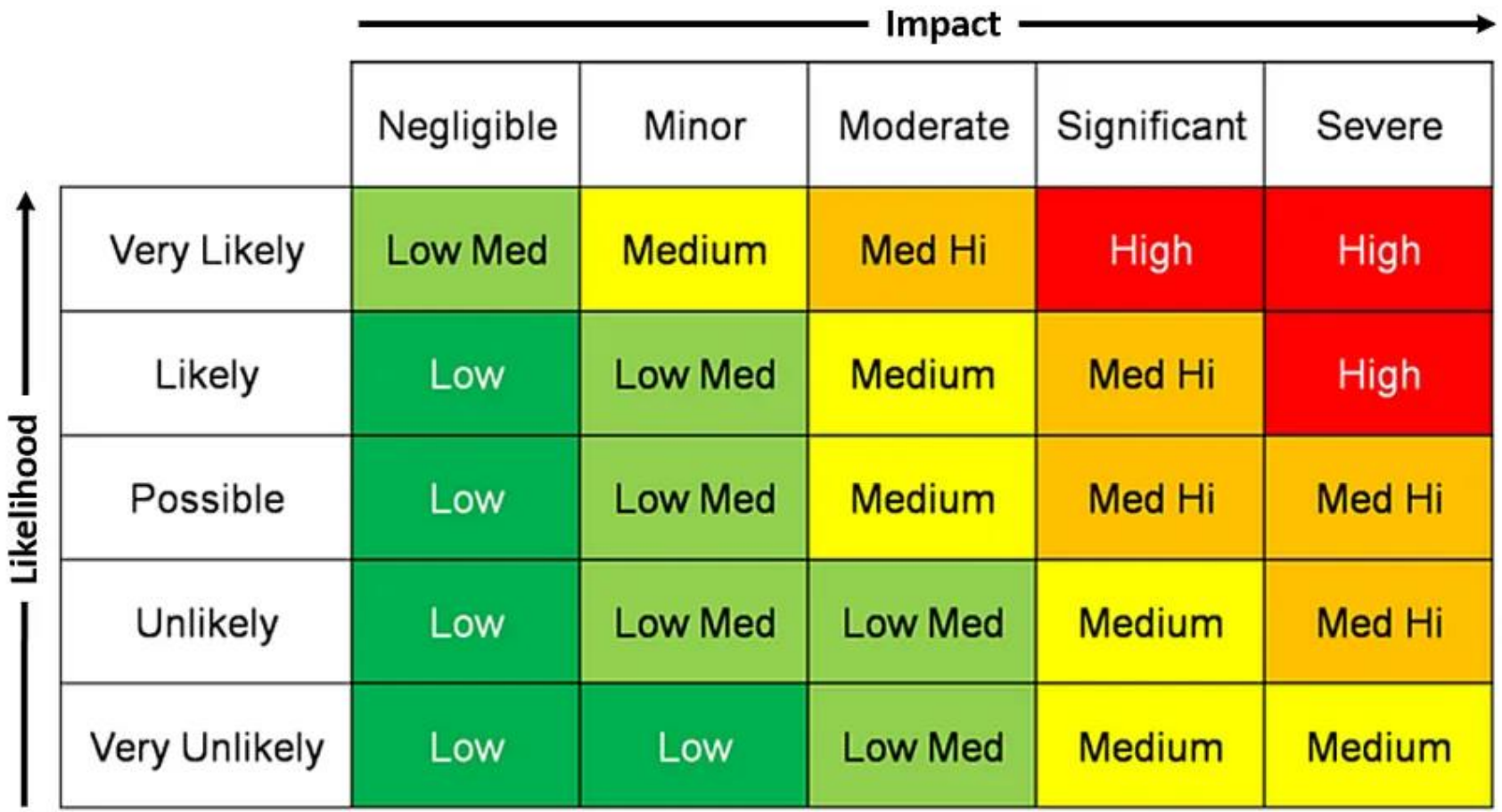

IMPACT
High
Medium
Low
Medium
High
High
Low
Medium
High
Low
Low
Medium
Low
Low
Medium
LIKELIHOOD

Risk matrix

- Likelihood
  - Low: Rare, doesn’t happen often but could happen
  - Medium: Likely to happen
  - High : Possibility of event happening often/ frequently
- Impact
  - Low : There will be no noticeable impact
  - Medium: impact is noticeable , business processes affected
  - High: most likely to cause disruption of the business, impact very visible.

Example

Simple IT Risk Matrix.xlsx


Impact
Negligible
Minor
Moderate
Significant
Severe
Likelihood
Very Likely
Low Med
Medium
Med Hi
High
High
Likely
Low
Low Med
Medium
Med Hi
High
Possible
Low
Low Med
Medium
Med Hi
Med Hi
Unlikely
Low
Low Med
Low Med
Medium
Med Hi
Very Unlikely
Low
Low
Low Med
Medium
Medium

Risk Treatment

- When risks have been analyzed organization's also decide on how they will treat/ respond to the risks
- There are four ways used to treat risks:
  - **Modify the risk** by applying security controls that will reduce the likelihood of it occurring and/or damage it will cause.
  - **Retain the risk** – accept that it falls within previously established risk acceptance criteria, or via extraordinary decisions.
  - **Avoid the risk** by changing the circumstances that are causing it.
  - **Share the risk** with a partner, such as an insurance firm or a third party that is better equipped to manage the risk.
- ISO 27001 requires all risks to have an owner who will be responsible for approving any risk treatment plans and accepting the level of residual risk. The person who owns risk treatment activities may be different from the asset owner.

Risk-Based Audit Approach

- Risk-Based Audit Approach is based on a concept in which determination of areas that should be audited is based on the perceived level of risk.
- So from the risk matrix, areas whose overall risk is high should be the ones that you focus on, in your annual audit plan.

IMPORTANCE OF IT RISK ASSESMENT DURING PLANNING

- The auditor needs to focus much of his efforts on high risk areas in a business and be ready to perform his own risk analysis and assessment in case it has not been done by the business itself or he founds it deficient.
- Most of the organizations would have an IT risk Matrix already developed, in this case the auditor may evaluate the Risk Matrix document provided , the auditor will evaluate whether adequate controls have been developed and implemented for high ranked areas.

Define Audit Objectives and scope

- The objectives and scope of an audit are derived from the risk assessment.
- The risk assessment process will help IS auditors to define the audit objectives, which focuses on addressing the high risk areas.
- IT audit objectives concentrate on validating that the internal controls exist and are functioning as expected to minimize business risk.
- The auditor should focus on high risk areas, to ensure that they are adequate controls implemented to prevent, detect and mitigate risks.

Define Audit Objectives and scope

Some of the common objectives of IT audit include:

- Review of security infrastructure and systems
- Review of IT systems to gain assurance of the safety
- Examine the development process and procedures involved at various stages of the system
- Evaluation of the performance of a specific program or system.

Define Audit Objectives and scope

- **The scope**, on the other hand, should define the boundaries, limits, or the periphery of the audit.
- Coming up with scope for an audit is part of audit planning and covers aspects such as the extent of substantive assessment depending on the control weakness, period of the audit, and the number of locations to be covered.
- Audit objectives and scope are not limited to the aspects mentioned above. It should be able to cover all the critical areas of the security aspect, such as security settings, passwords, firewall security, user rights, physical access security, and so on.
- i.e **Our audit objective** for auditing physical access to lab 1 and 2 could be:
  - To determine that physical access to IT computing resources is appropriately restricted.
- **Scope:** The scope of this audit will review IT laboratories under ICT namely lab 1 and lab 2

Define Audit Objectives and scope

- Kickoff meeting: Kick off meeting/ entry meeting must be conducted. kickoff meeting should occur with the audit client so that you can communicate what is in and out of scope for the audit project and also receive their final input.
- The kick-off meeting is also a great time to solicit primary points of contact for each audit step and to determine a schedule and methodology (such as meetings or e-mails) for keeping the customers informed of the audit's status.

Need to define audit Plan

- The audit plan refers to the scheme formulated by the auditor that is part of the strategy or approach, which is followed to carry out the audit.
- The audit plan can be understood as the plan to carry out the audit of an organization, which includes strategies or guidelines.
- The audit plan goes hand in hand with the audit program
- An audit program is the plan of the audit plan, which specifies how the audit will be carried out, who will perform it and what are the steps to follow to carry out it. It is a set of instructions that the audit staff pursues for the correct execution of the audit.

Need to define audit Plan(cont.)

An IT audit program will comprise of steps and procedures that the IS auditor will carry out in order to evaluate the adequacy of the controls within the organization and its IT environment.

It will normally highlight the objectives of the audit, then it will list all the procedures that will be carried out to achieve the objectives. (The format may vary.)

ISACA Standard 1201 on Engagement Planning states that the IT auditor should develop and document an IS audit or assurance engagement project plan.

Need to define audit Plan(cont.)

A best practice requires an Audit Program to contain the following;

- Description of the audit area
- Audit objectives
- Criteria and resources for each audit step
- Work paper reference
- Auditor that performs the audit
- Dates the audit were performed
- Comments (e.g. If not applicable and why)
- Conclusion

Audit Programs

- Audit programs are essentially checklists of the various tests that auditors must perform within the scope of their audits to determine whether key controls intended to mitigate significant risks are functioning as designed.

Description	[Describe the nature and intended usage for the program here]
Revision Info	This program was last reviewed/updated on [Click to Insert Date here]

Step	Audit Procedure	Perf'd/ Approved By	Workpaper Reference
	BACKGROUND & PLANNING		
1.	Obtain adequate background information on the audit area such as: • General ledger account listing • Audit reports from other audit and/or compliance groups • Productivity and performance measurement reports/stats • Financial reports/statements • Policies & Procedures • List of information technology applications utilized • List of laws and regulations		
2.	Review policies and procedures for completeness verifying they at a minimum address compliance with laws and regulations.		
3.	Examine productivity and performance measures for trends to assist in the developing audit scope.		
4.	Review financial reports/statements for unusual trends/fluctuations.		
	INFORMATION SYSTEMS		
	The following represents general information systems testwork to be performed if warranted based on the risk posed by individual systems.		
5.	Determine and list the primary information systems utilized within the operations. Consider performing the following testing based on the risk.		
6.	Review the process for granting and terminating user access. Perform detailed testing to determine if access is terminated timely.		
7.	On a sample basis, test specific user access to determine if access is commensurate with job functions. Additionally, determine if access promotes adequate segregation of duties.		

PREPARED BY:	AUDIT PROGRAM	Author: Lance M. Turcato
APPROVED BY:	Logical Security Operating Systems - Generic	Audit Date: _____

Assigned	Sec.	Sub-Sec.	Audit Step	Date	Ref.	Initials
	A		**SYSTEMS UNDERSTANDING**			
	A	1.0	**Organization** Objective: To ensure that the audit team has a clear understanding of the delineation of responsibilities for system administration and maintenance.			
	A	1.1	Determine who is responsible for systems administration and maintenance. Obtain a current organization chart if available.			
	A	2.0	**Hardware Platforms** Objective: To ensure that the audit team has a clear understanding of the hardware platforms subject to review and to obtain the necessary information for identifying critical systems throughout the processing environment.			
	A	2.1	Obtain an understanding of the server infrastructure at the site under review: • Request a complete server inventory. If an inventory is not available, obtain an understanding of the server environment through discussions with the system administrator(s). • If a server inventory is unavailable, meet with systems administration personnel and tour the facility to identify all servers and collect information regarding each server. • At a minimum, obtain the following information for each server included in the scope of the review: ▪ Server name ▪ Manufacturer and model ▪ Purpose / function of each server ▪ Owner ▪ Enterprise supported ▪ Responsible systems administrator • Identify the key servers that support business applications.			
	A	2.2	Obtain an understanding of the peripherals in the environment (i.e., printers, shared disks, etc.).			
	A	2.3	Determine if there are known problems with servers in the environment.			
	A	3.0	**Operating System** Objective: To ensure that the audit team has a clear understanding of the operating system included in the scope of the review. Furthermore, to ensure that known vulnerabilities associated with specific operating system versions are considered during the audit to ensure that all exposures are identified.			
	A	3.1	Ascertain which version(s) of the operating system are running on the servers included in the scope of the audit.			
	A	3.2	Determine if the most current version of the operating system is installed. If not, evaluate the justification for why the most current version is not installed.			
	A	3.3	Ascertain whether all known operating system fixes have been installed. If not, evaluate the justification for why available fixes have not been installed.			
	A	3.4	Determine if procedures are in place to ensure that system administration personnel are informed of available operating system fixes in a timely manner.			
	A	3.5	Determine if third-party security software is running on the servers.			
	A	4.0	**Network Overview** Objective: To ensure that the audit team has a clear understanding of network components and interfaces which may impact the logical security of specific servers and workstations.			

Field work and documentation

- Fieldwork is the phase where most of the heavy lifting will take place. One of the first things an auditor will ask for is information relating to your process and procedures. They want to see how well these accomplish the successful implementation of your policy and related control standards.
- They will interview system administrators to determine how they perform their duties daily and then check for supporting documentation. Having written operating procedures is always best.
- Once the auditor has identified all of the controls, they will review for effectiveness. Before even looking at the system, the auditor will try to ascertain if a control can meet a policy objective. They will look at the control and assume it has been implemented correctly and consistently. They will also consider the technology aspect of the control and the system it was meant to protect.

ISACA STANDARDS ON EVIDENCE

ISACA IS Audit and Assurance Standard 1205 - Evidence has the following provisions with regards to evidence

- IS audit and assurance professionals shall obtain sufficient and appropriate evidence to draw reasonable conclusions on which to base the engagement results
- IS audit and assurance professionals shall evaluate the sufficiency of evidence obtained to support conclusions and achieve engagement objectives.

Types of Audit Evidence

- Evidence is any information used by IS auditors to determine whether the client or the data being audited follows the established criteria or objectives and supports audit conclusions.
- The three main types of audit evidence include:
  - Documentary audit evidence
  - Analysis
  - Observed process and existence of physical items

Techniques for gathering evidence

The following methods can be used for the collection of audit evidence:

- Reviewing IS organization structures, policies and system documentation
- Interviews
- Questionnaire
- Flowcharts
- Walk through

Reviewing IS organization structures, policies and system documentation

- IS auditor should review and understand organizational controls in order to understand the controls that the organization has implemented and how these are implemented within the organizational structure.
- Auditors should also review Information system policies and procedures for the organizations, together with the Standards that the organization implements(i.e COBIT or ITIL)
- **NOTE:** Most of this review would have been done during the planning phase. The information review done in the planning phase feeds into the evidence collection phase thus the IS audit process is iterative and dependent on previous stages.

Interviews

- Interviews can be used to collect both quantitative and qualitative evidence during the collection work.
- There should be a clear objective for the interview. IS auditors should remember to use interviews as an audit gathering technique.
- Some of the persons to interview include systems analysts to better understand controls and functions within the security system, data entry personnel to determine the methodology they use to enter the data being detected by the system as incorrect, inaccurate, or malicious.
- Once the interview is done, the IS auditor should verify the notes captured with the interviewer.

Sample interview questions

- Do you have documented procedures to carry out weekly/daily backups?
- Are these procedures updated?

Questionnaires

- Traditionally, questioners have been used to evaluate controls within the system being audited.
- In some cases, auditors have creatively used questioners to flag specific areas of the system weakness in the course of evidence collection.
- In preparing the questioners, questions should be as specific as possible, and the language used should be that which commensurate with the targeted person understanding.

IT - General Controls Questionnaire

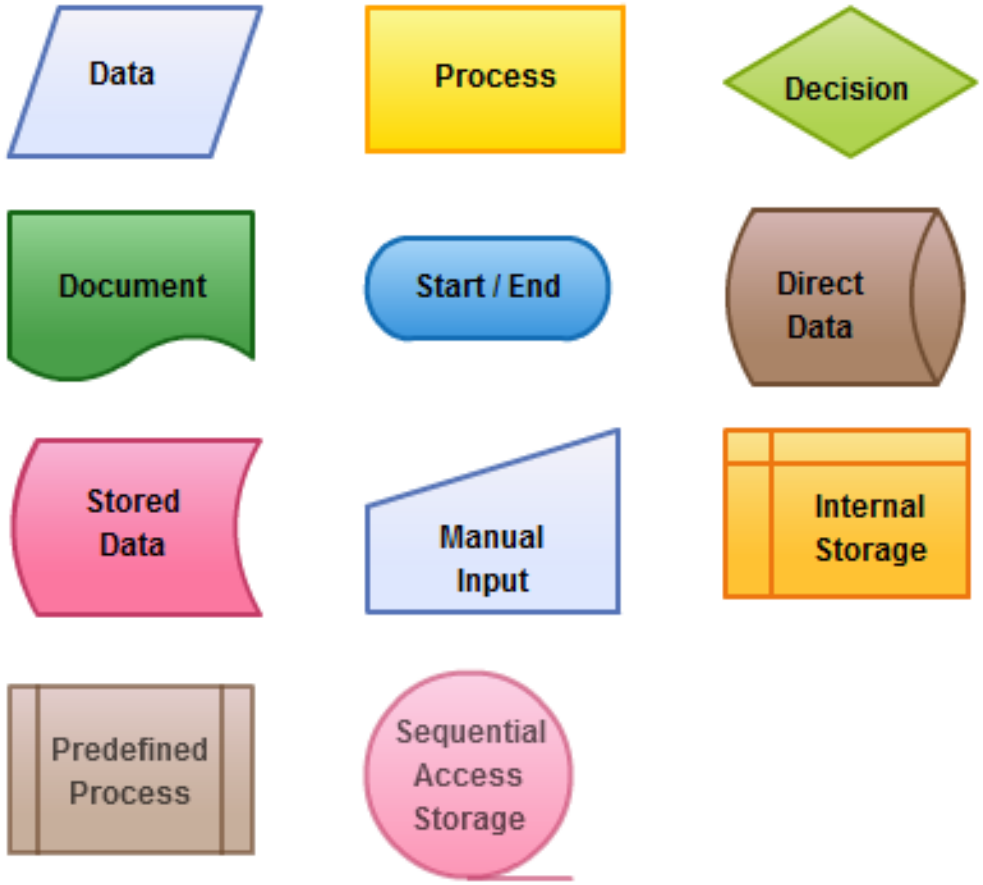
Internal Control Questionnaire

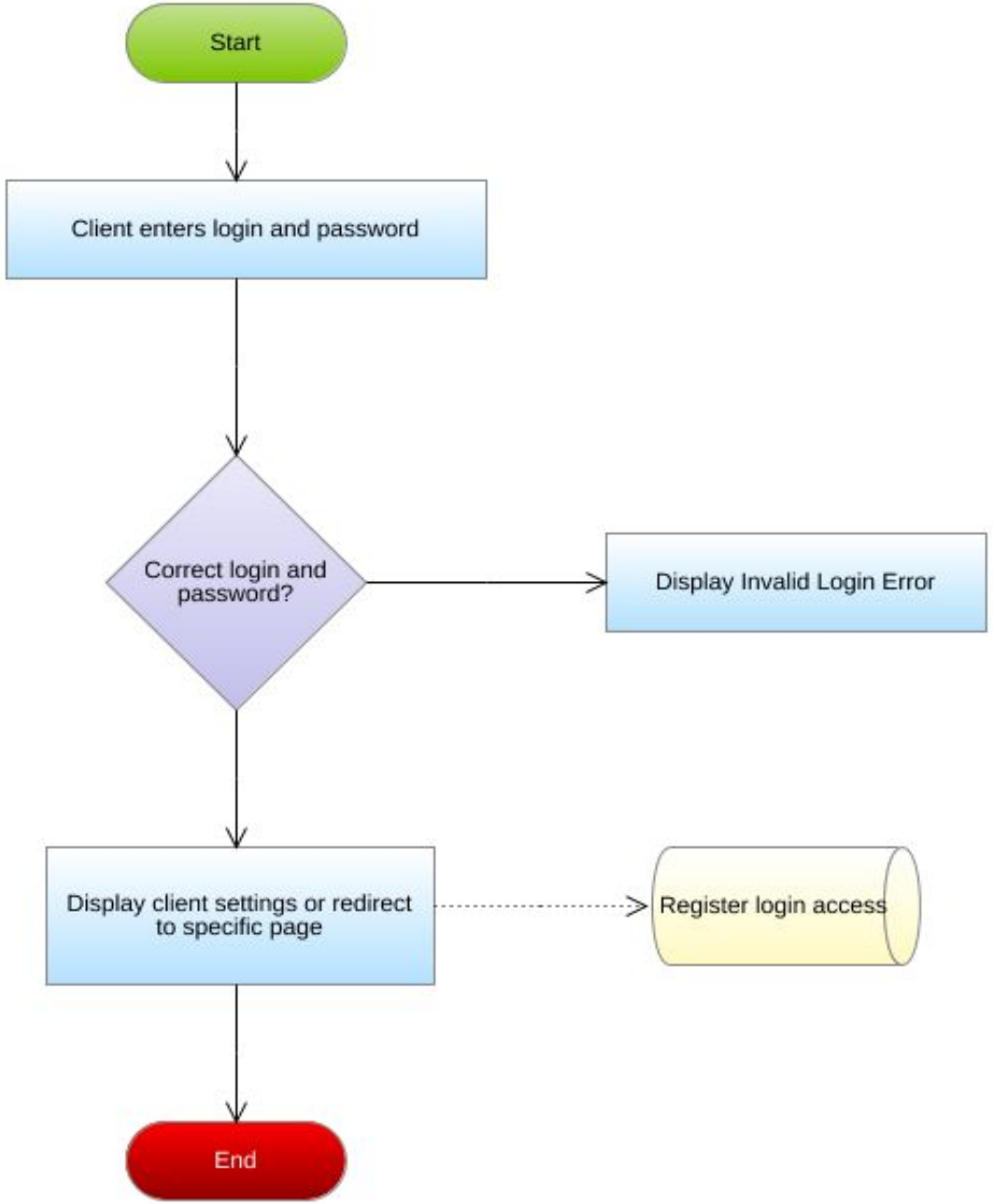
Question	Yes	No	N/A	Remarks
G1. ACCESS CONTROLS				
Access controls are comprised of those policies and procedures that are designed to allow usage of data processing assets only in accordance with management's authorization. Protection of these assets consists of both physical and logical access controls that prevent or detect unauthorized use, damage, loss, or modifications. The data processing resources to be protected include the system software, application programs and tables, transaction detail and history files, databases, documentation, hardware, and tape or cartridge libraries. Access to these resources should be limited to those individuals authorized to process or maintain a particular system.				
PHYSICAL SECURITY				
1. Does the university maintain written procedures relating to controls over the physical security of the computer equipment?				
2. Is the physical location of the computer/server/storage/training rooms appropriate to ensure security?				
3. *Are physical access devices (i.e., card-key or combination lock systems) used to restrict entrance to the computer room?				
4. Obtain documentation listing all individuals with access to the				

Flowcharts

- Flowcharts are designed to show that controls are embedded in the system and their specific locations within the system.
- They are fundamental for comprehension, evaluation, and communication during the audit.

Flowchart Symbols





Example
User login

Example

Reviewing the user creation process in the ABC Accounting information system. A user has to fill a form which is checked for completion and signed by the immediate supervisor, next the form is forwarded to the manager for checking and signing. After which its sent to the IT dept for the user to be created with their specific roles. If the form is incomplete the IT dept sends it back to the user. If the form is complete they should create the user.

Walkthrough

- A walk-through test traces a transaction/ internal control step-by-step from its inception to the final disposition.
- Walkthroughs are mostly done to confirm if auditors understand the organizational internal controls.
- Example: In conducting a walk-through test, an auditor will study how a transaction is initiated and moves through a company or organization's accounting system to completion. This involves identifying how a transaction is authorized, recorded—manually, by automated means, or both—and then reported in the general ledger of the books. The auditor will want to know how controls for accuracy are applied at each step in the process and how follow-up steps are taken to improve controls.

Working papers

- The results or information collected from the various audit evidence collection, is documented in working papers.
- **Audit working papers** are the documents which record all audit evidence obtained during financial statements auditing, internal management auditing, information systems auditing, and investigations.
- Audit working papers are used to support the audit work done to assure that the relevant auditing standards performed the audit.
- They provide evidence that sufficient information was obtained by an **auditor** to support his or her audit opinion

Working papers

- Working papers are an essential part of every audit for effectively planning the audit, providing a record of the evidence accumulated and the results of the tests, deciding the proper type of audit report, and reviewing the work of assistants.
- Format of working papers may also vary from one organization to another.
- In some cases IS Auditors may require to develop their own work papers.
- Work papers should have detailed evidence which can be presented to the auditees, Auditors may take pictures or detail the observations made.
- Observation may be included on the work paper, or an observation sheet that details the findings may be developed as well.

Contents of Working Papers

Each audit working paper must be headed with the following information:

- The name of the client
- The period covered by the audit
- The subject matter
- The file reference
- The initials (signature) of the member of staff who prepared the working paper, and the date on which it was prepared
- In the case of audit papers prepared by client staff, the date the working papers were received, and the initials of the audit team member who carried out the audit work
- The initials of the member of staff who reviewed the working papers and the date on which the review was carried out.

Example of working papers

Audit Work Paper Sample

Example

Analyze user password to determine if users adhere to password policy by changing their passwords every 3 months.

1. Sample some users and ask when they last changed their password. Document information given and analyze if they have changed their password in the last 3 months.
2. Extract system User policies and review if users have changed passwords in the last 3 months.

Example

User Name	Dept	Changed password past 3 months?
APhiri	ICT	yes
SBanda	ICT	No
PMoyo	Accounts	No
LMagula	Administration	No
AThom	Account	Yes

Reporting

The first thing in the auditor's report will be their opinion statements on the overall effectiveness and efficiency of the controls in your organization.

The second portion of the report is the recommendations section. Auditors will not specify step by step how fix the deficiencies they have observed, they will tell you what needs to be fixed but not how to fix it.

During this phase, you'll also need to develop a timeline for remediating any identified control deficiencies.



Structuring the report

The report should be complete, exact, objective, clear, timely, and precise as the subject allows. Your report can be generally structured under the following titles:

- Introduction
- Objectives, Scope, and Methodology
- Limitations
- Findings
- Conclusions
- Recommendations

Introduction

- The report should start with a brief description of the specific audit being taken up.
- **The overview** may entail details of the system, such as the description of the software's environment, resources required to run the system, and some details on the application being used.
- This is so that the reader can have a clear understanding of what the report is all about and stimulate them to appreciate the subsequent findings of the audit.
- You have to state the extent of the criticality of the system as most observations get their degree of seriousness from how criticality of the system has been defined.

Objectives, Scope, and Methodology

- In this section, you need to explain the objectives, scope, and methodology of the audit.
- This is to enable readers to understand the specific purpose of the audit, understand challenges faced, and to be able to make sound judgments on the merits of the audit work done.
- In the scope section, the auditor is expected to describe the depth of the work or in-put made to achieve the audit's objectives.
- Auditors should point out the specific organization audited, Hardware and software used, geographic locations, the period covered by the audit, explain sources of the evidence presented, and finally to explain the quality of the challenges or defects with the evidence.
- The methodology should explain the know-how of techniques used to gather and analyze the identified risks.

Limitations

- Generally, when the auditor does not receive all information and explanations that he deems necessary for the completion of the audit, limitation of scope arises.
- Limitations may be imposed by client or circumstances beyond both client and auditor.
- Circumstances that may limit a scope include: Timing of the field work inability to document adequate evidence

Findings

- Auditors are to report significant findings concerning audit objectives. In doing so, the auditor should include sufficient, relevant, and competent information to facilitate an adequate understanding of the issues being reported.
- The information presented should also be precise to provide convincing to the readers. This can be achieved by providing elaborate background information about the audit.

Findings

- Audit findings are provided in the audit report when action is required to correct a deficiency in a process or its related controls.
- Audit findings are derived from the audit methodologies that the auditor used and evidence documented in the work papers.
- The five key elements, or attributes that should be addressed when presenting an audit report are: Condition, Criteria, Cause, Effect and recommendations.

Condition	Describes the auditor finding, it is a statement of the problem observed. This maybe in terms such as control weakness, operational problems or noncompliance with management policies or defined standards
Criteria	Statement of requirement and identification of the baseline that was used for comparison against the auditors findings.
Cause	Cause may require the indentification of the responsible party. Responsible persons in the report should be either a business unit or a persons title.
Effect	This answers the question so what? It explains the adverse impact to the operational or control objective by articulating impact and risk. The element of effect is very important in helping to persuade the client to take corrective action
Recommendation	The corrective action should eliminate the problem or the deficiency noted in the condition. The corrective action should be directed towards addressing the cause.

Recommendations

- Where the report findings substantiate room for potential improvements, then the auditor should report recommendations. In cases of significant noncompliance with laws and regulations of the land or where there is considerable weakness in controls, then recommendations should be made that effective compliance and abidance by the law.
- Auditors should also address uncorrected findings and recommendations from past audits and how they affect the current audit and recommendations.
- Constructive recommendations are those which aim at solving the identified cause of problems, feasible and directed towards relevant authority who can act.
- The recommendations should, therefore, be practical, achievable, and cost-effective.

Management comment or response

- This section is written by the client/management.
- Auditors should reserve a section for Management Comments, the comments are included in the draft report which the auditors submit to the auditees before the exit meeting.
- They include actions that they will take in order to implement the recommendations that the report has highlighted.
- Management response will form part of the final audit report.

Activity

IT auditors reviewed XYZ and one of the findings was:

I. A good number of
II. Users did not change their passwords within the specified 3 months period.
III. The audit found that there were no physical controls implemented within the Data center.
IV. There was no fire detection and suppression system/mechanisms installed in the data center.

Determine the Criteria, Cause, effect and recommendation.

Management Response

Management response	Responsibility
Information system security section will carry out security awareness trainings to ensure users adhere to the password policy	Information security Section
Developers to send system messages every three months for users to change password.	ICT- Head of Programmers

Follow -up

- Usually happens few months after the report has been submitted.
- Purpose is to check if the recommendations that were implemented by the auditee.

Thank you !!